

AI Supplier Readiness Assessment

A practitioner framework for organisations navigating SSPA DPR v12
Section K compliance

Microsoft released SSPA DPR Version 12 in April 2026. Section K (AI Systems) has 18 requirements, 15 of which were updated. Suppliers with AI systems that cannot demonstrate compliance may create procurement and onboarding implications depending on supplier profile and programme requirements. For Sensitive Use AI, ISO 42001 certification is required under the programme. Refer to the SSPA Program Guide for definitions and requirements applicable to your profile.

POTENTIAL BUSINESS IMPLICATIONS

- Delayed or blocked purchase orders across Microsoft engagements
- Revenue recognition delays on affected contracts
- Extended onboarding where Microsoft validation is required
- Additional audit cost and rework from late-stage gap discovery
- Supplier reputation impact in Microsoft partner networks

READINESS SNAPSHOT

8 to 10 Strong baseline: consider formal assessment

4 to 7 Gaps likely: targeted review recommended

0 to 3 Material exposure: immediate attention needed

Scoring: Yes = 2 · Partially = 1 · No = 0

FIVE QUESTIONS TO ASK NOW

Q1 Have you identified whether your AI systems may qualify as Sensitive Use under SSPA v12?

TYPICAL GAP

- AI in hiring, credit, healthcare, or workplace monitoring not formally reviewed
- No internal review of Sensitive Use definitions in the SSPA Program Guide

SSPA CONSIDERATION

- Sensitive Use classification determines which compliance path applies
- Review Program Guide definitions carefully for your specific profile

Q2 Do you have a complete inventory of AI systems mapped to Section K requirements?

TYPICAL GAP

- AI tools used in Microsoft delivery not centrally documented
- No mapping between AI systems and DPR Section K controls

SSPA CONSIDERATION

- A complete inventory is typically required at assessment
- Confirm current requirements with your SSPA preferred assessor

Q3 Have you completed an AI Impact Assessment for each in-scope AI system?

TYPICAL GAP

- Risk assessments cover security but not AI-specific individual impact
- No documented assessment of bias, fairness, or societal considerations

SSPA CONSIDERATION

- Impact assessment depth is a common focus area in Section K reviews
- Review Section K requirements for your specific supplier profile

Q4 Have you defined whether AI governance will operate within your existing ISMS or through a separate AI management structure?

TYPICAL GAP

- ISO 27001 ISMS extended with AI language but governance boundaries not formally defined
- AI-specific risk criteria not addressed separately from information security risk

SSPA CONSIDERATION

- Review whether your governance structure meets Section K expectations
- Confirm approach with a Microsoft preferred assessor for your profile

Q5 Have you selected your compliance path and confirmed your timeline?

TYPICAL GAP

- No decision made on assessment approach or named ownership
- ISO 42001 timeline not scoped against programme requirements

SSPA CONSIDERATION

- Confirm compliance path options with an SSPA preferred assessor
- With existing ISO 27001, ISO 42001 typically takes 4 to 6 months

AI Governance Rapid Assessment

Duration: 1 week

ISO 42001 Readiness Accelerator

Duration: 3 to 6 weeks

Fractional AI Governance Advisor

Duration: Ongoing

- ✓ AI inventory review
- ✓ Sensitive Use classification review
- ✓ AI impact assessment review
- ✓ Gap analysis
- ✓ Executive findings summary
- ✓ AIMS scope definition
- ✓ Policy and governance structure
- ✓ Risk assessment framework
- ✓ Control mapping
- ✓ Remediation roadmap
- ✓ Ongoing governance guidance
- ✓ Risk and policy review
- ✓ Executive support
- ✓ Third-party AI risk review

COMMON PATTERNS IN ORGANISATIONS THAT STRUGGLE WITH SECTION K

- ✗ AI systems were never formally inventoried or classified by risk or use case
- ✗ Ownership was assumed but never formally assigned to a named individual
- ✗ Impact assessments were treated as documentation exercises rather than genuine risk analysis
- ✗ Compliance path decisions were deferred until too late to achieve required certification

Practitioner observation: Organisations rarely struggle with choosing a framework. They struggle with ownership, inventory accuracy, and implementation sequencing.

Ramya Amballa

AI Governance · GRC · ISO 27001 · Third-Party Risk
linkedin.com/in/amballa-ramya · aiforui.substack.com · ramyavibes2.gumroad.com ·
github.com/ramya-amballa

Practitioner Brief · Version 1.0
For discussion and governance assessment purposes
only. Not legal advice and not an official Microsoft
interpretation.